

DOKUMEN ANALISIS RISIKO KEAMANAN

INFORMASI & MITIGASI

Nama Sistem Aplikasi: SmartStock Pro (Sistem Manajemen Inventaris Gudang)

Ruang Lingkup Keamanan: Modul 1 (Autentikasi Sesi, Hak Akses, dan Proteksi Data Terhadap Ancaman Siber)

1. Identifikasi Aset Kritis Sistem

Sebelum melakukan pemetaan terhadap ancaman dan celah keamanan, berikut adalah komponen aset digital kritis di dalam aplikasi SmartStock Pro yang wajib dilindungi:

- Data Kredensial Pengguna (Tabel users):** Menyimpan data username, email, dan password dari seluruh aktor sistem (Admin, Manajer Gudang, Staf Gudang, dan Viewer).
- Data Operasional Inventaris (Tabel barang):** Menyimpan seluruh data logistik, kode barang, stok awal, serta informasi relasi lokasi gudang yang krusial bagi bisnis perusahaan.
- Data Rekam Jejak Forensik (Tabel audit_logs):** Menyimpan seluruh log aktivitas pengguna, termasuk data stempel waktu (timestamp), peran akun, jenis aktivitas, hingga alamat IP pelaku untuk kebutuhan audit independen.

2. Matriks Analisis Risiko Keamanan (Metode Likelihood & Impact)

Metode pengukuran risiko ini menggunakan standarisasi parameter industri:

- Likelihood (Kemungkinan Terjadi):** Skala 1 (Rendah) sampai 3 (Tinggi).
- Impact (Dampak Kerusakan):** Skala 1 (Rendah) sampai 3 (Tinggi).
- Risk Level (Tingkat Risiko):** Hasil perkalian antara Likelihood $\times$ Impact (Skala Total 1–9).

ID Risiko	Deskripsi Ancaman / Celah Keamanan	Likelihood	Impact	Risk Level	Status Mitigasi
R-01	Kebocoran database yang mengakibatkan password terekspos akibat disimpan dalam bentuk teks biasa (Plaintext).	3	3	9 (Kritis)	Berhasil BCRYPT Hashing.
R-02	Injeksi query database melalui form input login atau manipulasi data form barang oleh attacker (SQL Injection).	2	3	6 (Tinggi)	Berhasil PDO Prepared Statements.
R-03	Pembajakan sesi login aktif (Session Hijacking) karena komputer ditinggalkan pengguna dalam keadaan tanpa pengawasan.	3	2	6 (Tinggi)	Berhasil Session Timeout otomatis.
R-04	Penyisipan skrip JavaScript berbahaya pada input nama barang yang mengeksploitasi browser pengguna lain (Stored XSS).	2	2	4 (Sedang)	Berhasil Output Escaping htmlspecialchars.
R-05	Pemalsuan request atas nama akun pengguna lain yang sedang aktif melalui tautan eksternal manipulatif (CSRF Attack).	2	2	4 (Sedang)	Berhasil Validasi Token CSRF unik.

3. Detail Implementasi Teknis Langkah Mitigasi (Arsitektur Kodingan)

Berikut adalah pembuktian arsitektur teknis kodingan PHP yang telah diterapkan pada sistem aplikasi untuk mematahkan kelima risiko di atas:

A. Pengamanan Kredensial dengan Password Hashing (Mitigasi R-01)

Sistem menerapkan pengamanan search secara kriptografi sehingga administrator database sekalipun tidak dapat melihat password asli pengguna. Enkripsi memanfaatkan fungsi bawaan PHP yang kokoh.

```
// Enkripsi search password kiriman user menggunakan algoritma BCRYPT sebelum query
INSERT dijalankan
$password_terenkripsi = password_hash($_POST['password'], PASSWORD_BCRYPT);
```

B. Pencegahan Kebocoran Basis Data via PDO Prepared Statements (Mitigasi R-02)

Aplikasi SmartStock Pro tidak lagi menggabungkan input pengguna secara mentah ke dalam baris perintah query SQL. Penggunaan tanda tanya (?) sebagai parameter pengganti menjamin input dianggap sebagai literal murni.

```
// Placeholder memisahkan perintah SQL asli dengan karakter masukan dari user luar
$sql = "INSERT INTO barang (kode_barang, nama_barang, kategori, stok) VALUES
(?, ?, ?, ?)";
$stmt = $pdo->prepare($sql);
$stmt->execute([$kode, $nama, $kategori, $stok_awal]);
```

C. Manajemen Proteksi Sesi Aktif dengan Timeout Otomatis (Mitigasi R-03)

Berkas kendali utama `auth.php` merekam stempel waktu interaksi terakhir dari pengguna. Jika sistem mendeteksi tidak ada aktivitas klik atau refresh halaman dalam batas durasi tertentu, token session akan dihancurkan secara permanen oleh server.

```
// Menghancurkan session jika batas waktu menganggur (idle time) telah terlampaui
if (time() - $_SESSION['last_activity'] > 900) { // Rentang waktu 15 menit
    session_unset();
    session_destroy();
    header("Location: login.php?pesan=timeout");
    exit;
}
$_SESSION['last_activity'] = time();
```

D. Netralisasi Injeksi Skrip Browser Menggunakan Fungsi Escaping Teks (Mitigasi R-04)

Seluruh variabel teks yang berasal dari database disaring ketat sebelum dicetak ke dalam tabel HTML dashboard maupun log logistik. Teks berbahaya seperti tag skrip otomatis dikonversi menjadi entitas HTML mati yang tidak dapat dieksekusi browser.

```
<!-- Menampilkan data secara aman dari serangan pembajakan cookie browser -->
<td><?= htmlspecialchars($row['nama_barang'], ENT_QUOTES, 'UTF-8') ?></td>
```

E. Validasi Request Transaksi Form Menggunakan Token CSRF (Mitigasi R-05)

Masing-masing form tambah, edit, ataupun hapus stok barang disisipkan string acak unik yang divalidasi silang dengan session server. Request ilegal dari luar domain aplikasi otomatis akan ditolak mentah-mentah.

```
// Contoh implementasi validasi token di sisi server pengolah form data
if (!hash_equals($_SESSION['csrf_token'], $_POST['csrf_token'])) {
```

```
die("Akses ilegal terdeteksi! Transaksi CSRF diblokir.");  
}
```

4. Kesimpulan Hasil Audit Internal

Berdasarkan implementasi arsitektur keamanan di atas, seluruh kriteria standar pengamanan untuk **Modul 1: Autentikasi dan Keamanan** pada aplikasi SmartStock Pro dinyatakan telah terpenuhi dengan predikat **Sangat Aman / Lolos Uji Kendali Risiko**. Dokumen ini dapat digunakan sebagai lampiran resmi dalam berkas laporan praktikum atau portofolio project.